

Data Protection Impact Assessment

SimplyExpat · Internal Document · Not for Publication

Prepared: May 2026
Controller: Karl Fasselt, Fürbringerstraße 25, 10961 Berlin
Contact: info@simplyexpat.de
Legal basis: Art. 35 GDPR — Data Protection Impact Assessment
Classification: Internal · Confidential

01 Description of Processing

SimplyExpat is a client-side web application that guides users through completing Berlin's Anmeldung (address registration) form. Users enter personal data — name, address, date of birth, passport number, citizenship, marital status, religious affiliation — into a browser form. This data is stored exclusively in the user's browser via localStorage and is never transmitted to SimplyExpat servers. PDF generation occurs entirely in the browser using pdf-lib.

The only data transmitted server-side is: (a) a Stripe session ID for payment verification, and (b) optionally a first name and email address for a transactional reminder email via Resend.

02 Necessity and Proportionality

The data collected is the minimum required to complete the official Anmeldung form under the Bundesmeldegesetz (BMG). No additional data is requested beyond what the official form requires. The service cannot function without these fields. The opt-in email field is strictly optional and contains functional data only (first name and email address).

03 Risk Assessment

Risk	Likelihood	Severity	Mitigation
Unauthorised server-side access to form data	None	n/a	Data never reaches the server — architectural elimination of risk
Browser localStorage XSS access	Low	High	Next.js CSP defaults; no user-generated HTML rendered
Religious affiliation (Art. 9 GDPR) exposure	Very Low	High	Stored locally only; SimplyExpat has zero technical access; Recital 26 applies
Email address misuse (Resend)	Low	Medium	Opt-in only; minimal data (email + first name); Resend DPA in place
Payment data breach	Very Low	High	SimplyExpat never receives card data; Stripe PCI-DSS Level 1
Data subject unable to exercise rights	Low	Low	Form data not held by SimplyExpat; deletion via info@simplyexpat.de

04 Special Category Data (Art. 9 GDPR)

The form includes a religious affiliation field, which constitutes special-category data under Art. 9(1) GDPR. Assessment: this field is processed exclusively in the user's browser and is never transmitted to or stored by SimplyExpat. SimplyExpat is therefore not a data controller for this field within the meaning of Art. 4(2) GDPR (see Recital 26: purely personal or household activity). The field is optional — users may select "None." Overall risk for this field: **Low**.

05 Technical and Organisational Measures

- All form data processed client-side only, in browser localStorage, automatically deleted after PDF generation
- No server-side logs of personal data at any point
- HTTPS enforced on all endpoints (Vercel deployment)
- Fonts self-hosted — no external resource requests on page load (Google Fonts removed)
- Stripe PCI-DSS Level 1 for all payment processing
- Art. 28 Data Processing Agreements: Stripe (accepted in Dashboard) and Resend
- Standard Contractual Clauses (SCCs) in place for US data transfers (Stripe, Resend)
- No analytics, no tracking cookies, no third-party advertising

06 Conclusion

The processing operations present **low overall risk** to data subjects. The core architectural decision — client-side-only form data processing — eliminates the primary risk category for this type of service (server-side data breach). No further measures are required at this time.

This assessment should be reviewed if: (a) server-side processing of form data is introduced, (b) analytics or tracking is added, or (c) the service expands beyond Berlin.

07 Review Schedule

Next scheduled review: **May 2027**

Earlier review required if: processing activities change materially, a data breach occurs, or new processing of special-category data is introduced server-side.

Prepared by	Date	Signature
Karl Fasselt (Controller)	May 2026	